

Narrativa explicativa de la Encuesta HTMM

1. De qué va realmente todo esto

La encuesta que tiene usted delante —o que está a punto de reenviar al departamento de “que lo rellene otro”— nace de una constatación sencilla: el modelado de amenazas se ha convertido en una pieza central de la seguridad moderna, pero su práctica real en las organizaciones oscila entre el arte, el ritual y la improvisación.

El Hybrid Threat Modeling Method (hTMM), propuesto por el Software Engineering Institute (SEI), intenta reconciliar esos mundos combinando creatividad (Security Cards), estructura (PnG, STRIDE) y disciplina de requisitos (SQUARE). [web:12][web:6][web:5] La encuesta quiere saber hasta qué punto esa filosofía —no necesariamente la liturgia exacta del método— ha aterrizado en la práctica diaria de las organizaciones.

2. Por qué preguntar tanto

Preguntamos mucho porque el estado del modelado de amenazas no se resume en un “sí” o un “no”. Pedimos detalles sobre métodos, frecuencia, ámbitos, indicadores, integración con riesgos, continuidad y ROI porque todas esas capas determinan si el esfuerzo de modelar amenazas se queda en ejercicio de estilo o se traduce en decisiones reales.

Además, los informes de paisaje de amenazas, como el ENISA Threat Landscape 2025, muestran un entorno cada vez más híbrido: DDoS masivos, ransomware profesionalizado, actores estatales y hacktivistas compartiendo herramientas, e incidentes que mezclan lo técnico con lo físico y lo informacional. [web:13][web:7][web:18] Si los modelos de amenaza no reflejan esa complejidad, nos estaremos contando un cuento más sencillo que la realidad.

3. A quién va dirigida la encuesta

La encuesta está pensada para responsables de seguridad (CISO, responsables de ciberseguridad), de riesgo, de continuidad, de TI/OT y, en organizaciones especialmente valientes, miembros de la alta dirección que quieran bajar de la estratosfera del “riesgo estratégico” a la geografía concreta de las amenazas.

No se espera que cada participante domine todas las siglas (hTMM, STRIDE, ATT&CK, CVSS); lo importante es que puedan describir con honestidad qué se hace, qué no se hace y qué se hace solo porque lo pidió el auditor. Donde sea necesario, la guía metodológica proporciona recordatorios conceptuales.

4. Qué se puede hacer con los resultados

Los datos obtenidos permiten, entre otras cosas:

- Dibujar mapas de madurez por sector y tamaño, identificando dónde abunda el modelado de amenazas y dónde sigue siendo una rara avis.
- Comparar la autopercepción de las organizaciones con la evidencia externa de incidentes en la UE, para ver si la atención prestada a determinados tipos de amenazas está alineada con su protagonismo real. [web:13][web:7][web:18]
- Diseñar programas de formación y herramientas que ataquen los puntos flacos más recurrentes (por ejemplo, la ausencia de métricas o la desconexión con el análisis de riesgos).

En un nivel más ambicioso, los resultados pueden alimentar estrategias nacionales de ciberseguridad, contribuyendo a definir mínimos razonables de modelado de amenazas para operadores de servicios esenciales y administración pública.

5. Sobre el IGM y el ROI (sí, dinero)

El Indicador Global de Madurez (IGM) no pretende ser un oráculo, sino una forma compacta de resumir, por organización y sector, hasta qué punto el modelado de amenazas está institucionalizado, integrado y alineado con la realidad de las amenazas. Se construye combinando puntuaciones de distintas secciones (método, cobertura, métricas, integración con riesgo, dimensión territorial, etc.).

En paralelo, la encuesta pregunta por el ROI del modelado de amenazas porque, mal que nos pese, muchas decisiones estratégicas respecto a métodos, herramientas y equipos se toman en función de su impacto económico percibido. Estudios recientes que combinan hTMM con marcos cuantitativos (STRIDE+ATT&CK+CVSS, matrices de riesgo 5×5) muestran que es posible aproximar pérdidas evitadas o mitigadas con cierto decoro numérico. [web:8][web:15]

6. Y ahora, qué

Una vez recogidas las respuestas, el trabajo de verdad empieza con el análisis: patrones por sector, correlaciones entre madurez y tipos de incidente, identificación de buenas prácticas exportables y de carencias sistemáticas.

El resultado ideal no es una clasificación de organizaciones “buenas” y “malas”, sino un espejo colectivo que permita a cada una situarse, justificar avances y, si se tercia, reclamar recursos adicionales con algo más que un PowerPoint alarmista.

Si tras completar la encuesta le queda la sensación de que faltan preguntas, es una buena señal: significa que en su organización ya se está pensando en el modelado de amenazas con una finura que quizá merezca un estudio propio.